GRC102 Week 3 Practical Laboratory

TechGlobal Governance Transformation Simulation

Field	Detail
Student Name	Adebukola Olanipekun
Registration Details	C11/26/CGRCE/17603 ,Cohort 11 CGRCE
Date	25 September 2026
Submission	Written consultant report + supporting governance artefacts

---

Task 1 Governance Architecture and Stakeholder Map

1.1 Governance Gap Assessment

TechGlobal's current “security by informal decision” model creates five material governance weaknesses:

Weakness 1: Concentration of authority in the IT Director

The IT Director simultaneously acts as security owner, risk approver, and operational decision-maker. There is no separation between the function that implements controls and the function that assures their effectiveness.

Business/risk consequence: No independent challenge to IT's risk assessments. Security investments are justified by the same person who benefits from them. The organisation cannot demonstrate that risk acceptance decisions are informed or legitimate. This mirrors the segregation-of-duties failure seen when the same team implements and self-assures controls.

Weakness 2: No formal governance committee structure

There are no standing forums where cross-functional security decisions are reviewed collectively. Decisions are made bilaterally between the IT Director and whoever raises the issue.

Business/risk consequence: Inconsistent decisions across business units; no mechanism for Legal, Finance, HR, or Risk to provide input before commitments are made. Regulatory and contractual exposure is not systematically assessed. The organisation lacks a documented decision trail, creating accountability gaps during incidents.

Weakness 3: Business units operate inconsistently with no security governance participation

Business-unit leaders make local security choices without a shared framework, and there is no route for them to participate in governance.

Business/risk consequence: Shadow IT, inconsistent control implementation, and “security silos” where each unit solves the same problem differently. Risk aggregation at enterprise level is impossible because local risk decisions are invisible to the centre. This is precisely the fragmentation the assignment warns against.

Weakness 4: Limited CEO and Board visibility into cyber risk

The CEO and Board receive no structured reporting on material cyber risk. There is no defined escalation path, no risk appetite statement, and no Board-level assurance mechanism.

Business/risk consequence: The Board cannot exercise its oversight duty. Material risks remain invisible until they crystallise into incidents. The organisation is exposed to regulatory criticism for inadequate governance, and directors face personal oversight exposure. Without Board visibility, security investment is perpetually under-prioritised relative to growth initiatives.

Weakness 5: No defined escalation path or risk-acceptance authority

There are no trigger criteria for escalating cyber risk, and no clarity on who may accept residual risk at what threshold.

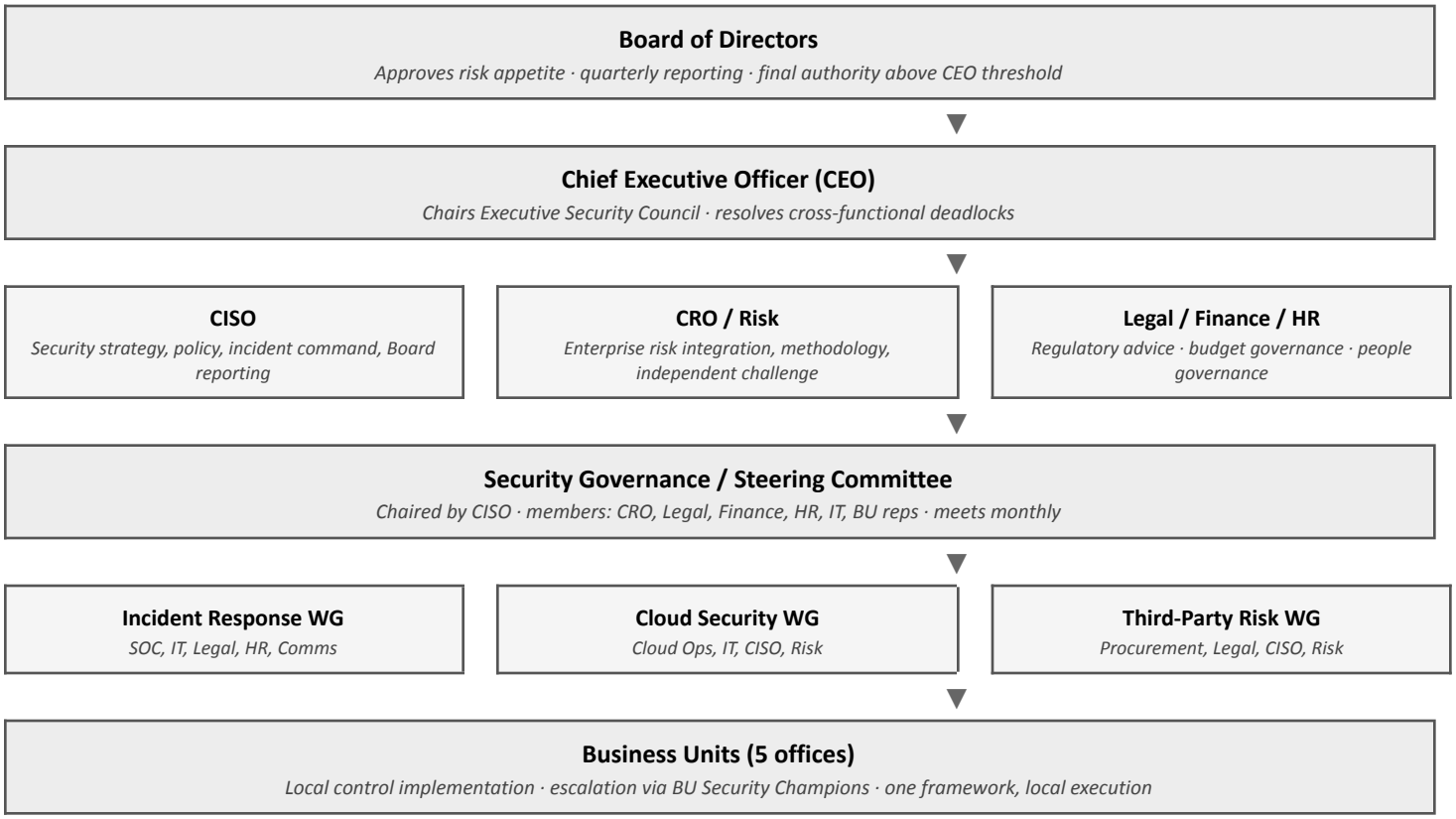
Business/risk consequence: Material risks are either escalated too late or never; risk acceptance happens by default rather than by decision. During an incident, response is delayed while people argue about who decides. Post-incident, there is no auditable record of who accepted what risk and why.

1.2 Stakeholder Map

Stakeholder	Authority / Influence	Primary Interest	Information Needed	Governance Contribution
Board of Directors	Ultimate oversight authority; approves risk appetite and strategy	Regulatory exposure, brand reputation, material risk, assurance, accountability	Quarterly cyber-risk dashboard; material incident briefings; annual independent assessment	Sets risk appetite; holds CEO accountable; approves enterprise risk acceptance above threshold
CEO	Executive authority; allocates resources; final management decision-maker below Board threshold	Growth, strategic alignment, acceptable risk, business performance	Weekly CISO briefings; immediate material incident notification; cross-functional risk summaries	Provides executive sponsorship; resolves cross-functional deadlocks; ensures security is business-aligned
CISO	Security governance leadership; incident response command; policy authority	Security strategy, policy, risk oversight, reporting, programme effectiveness	Operational incident data; control effectiveness metrics; regulatory exposure trends	Designs and operates the security governance framework; provides independent risk visibility to CEO and Board
CRO / Risk	Enterprise risk integration; risk methodology owner; independent challenge	Risk methodology, risk acceptance, treatment, enterprise aggregation	Risk register entries; risk quantification; escalation documentation	Ensures cyber-risk is integrated into enterprise risk management; validates risk ratings; co-owns risk acceptance
Legal / Compliance	Regulatory and legal advice; notification decisions (joint with CISO)	Regulatory duties, contractual obligations, privacy, evidence, notification	Incident facts; regulatory exposure classification; contractual terms	Provides legal guardrails; determines notification obligations; protects privilege; advises on disclosure
Finance	Budget governance; financial risk quantification	Budget, loss exposure, investment prioritisation, financial controls	Cost impact data; investment proposals; risk-adjusted ROI analysis	Quantifies financial impact; validates security investment business cases; ensures budget transparency
HR	People governance; disciplinary authority	Joiner/mover/leaver controls, awareness, conduct, disciplinary processes	Awareness metrics; policy violation reports; insider threat indicators	Owns security culture and awareness programme; enforces disciplinary process; manages insider threat policy
IT / Technology	Technology delivery; implementation authority	Secure operation, implementation, technical control ownership, service continuity	Security requirements; architecture standards; vulnerability data	Implements and operates controls; remediates vulnerabilities; provides technical evidence for assurance

Stakeholder	Authority / Influence	Primary Interest	Information Needed	Governance Contribution
Business Unit Leaders	Business ownership; local risk decisions within framework	Operational performance, local risk decisions, control implementation	Security requirements relevant to their unit; incident impact data; governance calendar	Implement controls in their units; participate in governance; escalate local risks through defined channels

1.3 Security Governance Organisation Chart



Communication Paths:

- Upward: BU → Steering Committee → Executive Security Council → Board
- Downward: Board → CEO → CISO → Steering Committee → Working Groups → BU
- Cross-functional: Steering Committee is the primary horizontal coordination forum
- Incident: SOC → CISO → CEO (immediate) → Board (material incidents)

1.4 Consultant Justification

Why this structure is appropriate for a 2,500-employee technology organisation across five offices:

Scalability without bureaucracy: A 2,500-employee organisation is large enough to require formal governance but small enough that excessive committee layers would slow decision-making. The three-tier model (Executive Security Council, Steering Committee, Working Groups) provides clear escalation without creating a maze of forums. Working Groups are established only where there is sustained operational need (Incident Response, Cloud Security, Third-Party Risk), avoiding "committee for everything" syndrome.

Business alignment through BU participation: The Steering Committee includes Business Unit representatives, ensuring that security governance is not an IT monologue. BU leaders participate in decisions that affect their operations, which improves implementation fidelity and reduces shadow IT. The "Security Champion" model within each BU provides a local point of contact without creating separate security functions.

Independent oversight with clear accountability: The CISO reports to the CEO with a dotted line to the Board Risk Committee. This preserves independence from IT while ensuring executive access. The CRO provides independent challenges to risk assessments. Legal, Finance, and HR have defined roles rather than ad hoc involvement. Every governance activity has one Accountable role (see Task 4 RACI).

Board visibility without Board micromanagement: The Board receives quarterly cyber-risk reporting and immediate notification of material incidents. It does not manage security operations. This aligns with the principle that boards should "support the Red and challenge the Green" — providing oversight, not operational command.

Five-office coordination: The Steering Committee includes representation from each office (via BU leaders or their delegates). Working Groups can hold virtual meetings across time zones. The governance calendar (Task 3) ensures regular touchpoints. Local implementation is standardised through policy and control frameworks, but execution adapts to local regulatory and operational contexts.

Regulatory and contractual compliance: The structure ensures Legal/Compliance has a defined seat at the governance table, with authority over notification decisions (joint with CISO). This prevents the common failure where legal review happens after commitments are made. Finance's participation ensures security investment is business-justified and budgeted transparently.

Incident readiness: The escalation workflow (Task 5) connects operational detection to Board oversight through defined trigger criteria and decision points. The Incident Response Working Group maintains playbooks and conducts exercises. The CISO has command authority during incidents, with CEO and Board escalation paths that are pre-defined rather than improvised.

Task 2 Governance Responsibility and Authority Matrix

2.1 Cross-Functional Governance Responsibility Matrix

Role	Purpose	Core Responsibilities	Decision Authority	Reports / Escalates To	KPIs / Evidence
Board	Ultimate oversight and accountability for enterprise risk	Approve risk appetite; oversee material cyber-risk; hold CEO accountable; approve strategy	Risk appetite; enterprise risk acceptance above CEO threshold; strategy approval	Shareholders; regulators	Quarterly cyber-risk dashboard; annual independent assessment; incident oversight records
CEO	Executive accountability for business-aligned security	Sponsor security strategy; allocate resources; resolve cross-functional deadlocks; represent security to Board	Resource allocation; operational risk acceptance below Board threshold; escalation decisions	Board	Security strategy execution; budget utilisation; incident response performance

Role	Purpose	Core Responsibilities	Decision Authority	Reports / Escalates To	KPIs / Evidence
CISO	Security governance leadership and independent risk visibility	Design governance framework; own security strategy and policy; command incident response; report to Board	Security architecture; policy approval (with CEO); incident command; risk escalation recommendations	CEO; Board Risk Committee	Incident response times; control effectiveness; risk register completeness; Board briefing quality
CRO / Risk	Independent risk integration and challenge	Own risk methodology; validate risk ratings; aggregate enterprise risk; challenge security assessments	Risk rating methodology; risk register inclusion; independent challenge authority	CEO; Board Risk Committee	Risk register currency; risk quantification accuracy; challenge documentation
Legal / Compliance	Legal and regulatory guardrails	Advise on regulatory obligations; determine notification requirements (joint with CISO); protect privilege; manage litigation risk	Regulatory notification decisions (joint); legal privilege determinations; disclosure content	CEO; Board	Notification timeliness; regulatory compliance; litigation outcomes
Finance	Financial governance and investment discipline	Quantify financial impact; validate security investment business cases; ensure budget transparency	Budget allocation within approved envelope; cost quantification methodology	CEO; Board	Budget variance; cost impact accuracy; ROI evidence
HR	People governance and security culture	Own awareness programme; enforce disciplinary process; manage insider threat policy; joiner/mover/leaver controls	Disciplinary actions; awareness programme mandate; insider threat policy	CEO	Awareness completion rates; policy violation trends; culture survey results
IT / Technology	Technology delivery and control operation	Implement and operate controls; remediate vulnerabilities; provide technical evidence; maintain service continuity	Technical implementation decisions within architecture; system changes	CISO; CIO	Patch compliance; vulnerability remediation times; control operation metrics
Business Unit Leaders	Business ownership and local implementation	Implement controls in their units; escalate local risks; participate in governance; ensure business continuity	Local operational decisions within framework; local risk escalation	CEO; Steering Committee	Local incident rates; control compliance; escalation quality

2.2 Role Profiles / Responsibility Cards

Board of Directors - Responsibility Card

Purpose: Provide ultimate oversight of cyber-risk and hold executive management accountable for security governance.

Key Governance Responsibilities:

1. Approve the enterprise cyber-risk appetite and security strategy.
2. Receive and challenge quarterly cyber-risk reporting from the CISO.
3. Approve risk acceptance above the CEO's delegated threshold.
4. Oversee material incident response and disclosure decisions.
5. Ensure adequate resources are allocated to security.

Decision Authority: Risk appetite; enterprise risk acceptance above threshold; strategy approval; CEO performance evaluation on security.

Reporting Obligations: To shareholders and regulators on material cyber-risk; to the CEO on expectations.

Performance Indicators: (1) Quarterly cyber-risk reporting received and minuted; (2) No material incidents where Board oversight was absent; (3) Risk appetite statement reviewed annually.

CEO — Responsibility Card

Purpose: Provide executive accountability for embedding security into business strategy and resolving cross-functional conflicts.

Key Governance Responsibilities:

1. Chair the Executive Security Council.
2. Allocate resources for security programme and incident response.
3. Resolve deadlocks between CISO, CRO, Legal, Finance, and IT.
4. Ensure the CISO has direct access to the Board.
5. Represent security governance to the Board and external stakeholders.

Decision Authority: Resource allocation; operational risk acceptance below Board threshold; escalation decisions; cross-functional deadlock resolution.

Reporting Obligations: To the Board on security strategy execution and material incidents.

Performance Indicators:

(1) Security strategy milestones achieved;

(2) Material incidents escalated within defined timeframes;

(3) CISO has unfiltered Board access.

CISO - Responsibility Card

Purpose: Lead security governance, provide independent risk visibility, and ensure security programme effectiveness.

Key Governance Responsibilities:

1. Design and operate the security governance framework.
2. Own the security strategy and policy framework.
3. Command incident response and escalate material incidents.
4. Report to the Board Risk Committee quarterly and on material incidents.
5. Maintain the cyber-risk register and recommend risk treatment.

Decision Authority: Security architecture approval; policy approval (joint with CEO); incident command; risk escalation recommendations.

Reporting Obligations: To the CEO weekly; to the Board Risk Committee quarterly and on material incidents.

Performance Indicators: (1) Critical incident SLA breach rate <25%; (2) Board briefing quality rating; (3) Risk register completeness and currency.

CRO / Risk - Responsibility Card

Purpose: Integrate cyber-risk into enterprise risk management and provide independent challenge.

Key Governance Responsibilities:

1. Own the enterprise risk methodology and risk register.
2. Validate cyber-risk ratings and challenge security assessments.

3. Aggregate cyber-risk with other enterprise risks.

4. Co-own risk acceptance documentation with CISO.

5. Report enterprise risk to the Board Risk Committee.

Decision Authority: Risk rating methodology; risk register inclusion; independent challenge authority.

Reporting Obligations: To the CEO and Board Risk Committee on enterprise risk aggregation.

Performance Indicators:

(1) Risk register currency (reviewed monthly);

(2) Challenge documentation completeness;

(3) Enterprise risk reporting timeliness.

Legal / Compliance - Responsibility Card

Purpose: Provide legal and regulatory guardrails for security governance and incident response.

Key Governance Responsibilities:

1. Advise on regulatory notification obligations.

2. Determine legal privilege and disclosure strategy.

3. Review contractual obligations for security requirements.

4. Manage litigation and regulatory investigation risk.

5. Participate in incident response governance.

Decision Authority: Regulatory notification decisions (joint with CISO); legal privilege determinations; disclosure content approval.

Reporting Obligations: To the CEO and Board on regulatory exposure and legal risk.

Performance Indicators: (1) Notification timeliness (100% within regulatory deadline); (2) No adverse regulatory findings on notification; (3) Contractual security clauses reviewed.

Finance - Responsibility Card

Purpose: Ensure financial governance of security investment and accurate cost impact quantification.

Key Governance Responsibilities:

1. Quantify financial impact of cyber incidents.

2. Validate security investment business cases.

3. Ensure budget transparency and cost control.

4. Provide financial input to risk acceptance decisions.

5. Report security investment performance to the CEO/Board.

Decision Authority: Budget allocation within approved envelope; cost quantification methodology.

Reporting Obligations: To the CEO and Board on security investment and cost impact.

Performance Indicators:

(1) Cost impact accuracy within 10%;

(2) Budget variance <5%;

(3) Investment business cases completed.

HR - Responsibility Card

Purpose: Govern people-related security risks and build security culture.

Key Governance Responsibilities:

1. Own security awareness programme.
2. Enforce disciplinary process for policy violations.
3. Manage insider threat policy and investigations.
4. Ensure joiner/mover/leaver controls are effective.
5. Report culture metrics to CEO.

Decision Authority: Disciplinary actions; awareness programme mandate; insider threat policy.

Reporting Obligations: To the CEO on culture metrics and disciplinary outcomes.

Performance Indicators:

(1) Awareness completion >95%;

(2) Policy violation trends decreasing;

(3) Insider threat investigations completed on time.

IT / Technology - Responsibility Card

Purpose: Deliver secure technology operations and implement controls effectively.

Key Governance Responsibilities:

1. Implement and operate security controls.
2. Remediate vulnerabilities within defined timeframes.
3. Provide technical evidence for assurance.
4. Maintain service continuity and recovery capability.
5. Support incident response with technical expertise.

Decision Authority: Technical implementation decisions within approved architecture; system changes.

Reporting Obligations: To the CISO and CIO on control effectiveness and vulnerability status.

Performance Indicators: (1) Patch compliance >95% within SLA; (2) Vulnerability remediation times within target; (3) Control operation metrics within tolerance.

2.3 Conflict-Resolution Note

Overlapping Authority 1: CISO and IT Director on Security Architecture

Conflict: The CISO owns security architecture approval; the IT Director owns technical implementation decisions. If the IT Director implements a solution that deviates from approved architecture, the CISO must either accept the deviation or escalate.

Resolution Principle: The CISO has final authority on security architecture. The IT Director may propose alternatives with documented risk assessment. If the IT Director disagrees with the CISO's decision, escalation is to the CEO, not to unilateral implementation. The Steering Committee is the forum for resolving architectural disagreements before implementation.

Overlapping Authority 2: CISO and CRO on Risk Acceptance

Conflict: The CISO recommends risk treatment; the CRO validates risk ratings and owns the enterprise risk register. If they disagree on whether a risk is acceptable, the decision could stall.

Resolution Principle: The CISO recommends; the CRO validates methodology and rating; the CEO accepts operational risk below Board threshold; the Board accepts enterprise risk above threshold. No risk acceptance is valid without both CISO and CRO assessment. If they disagree, the disagreement is documented and escalated to the CEO with both positions.

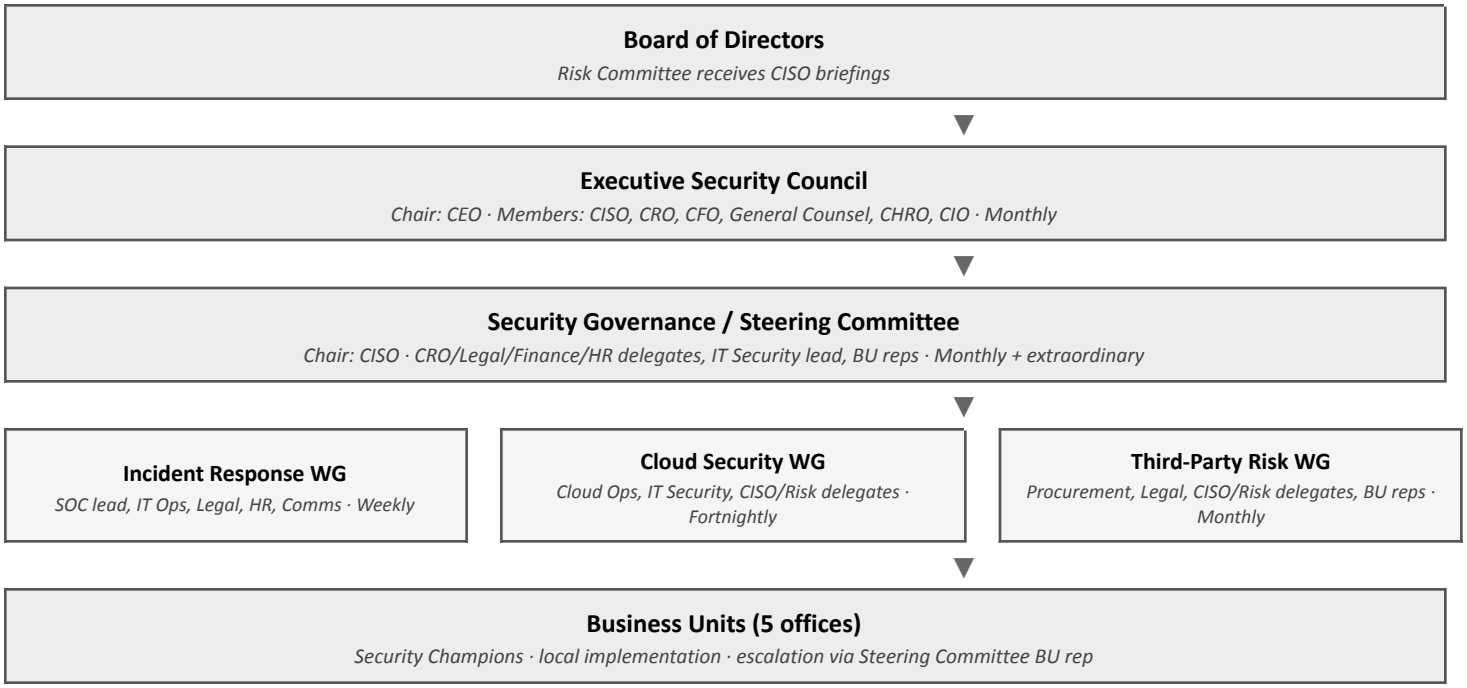
Overlapping Authority 3: Legal and CISO on Regulatory Notification

Conflict: Legal owns regulatory notification decisions; the CISO owns incident facts and technical assessment. If Legal wants to notify but the CISO believes the incident is contained, or vice versa, the notification decision could be delayed.

Resolution Principle: Notification is a joint decision requiring both Legal's regulatory assessment and the CISO's factual confirmation. If they disagree, the CEO decides, with Legal's regulatory risk assessment given priority where deadlines are imminent. The default is to notify unless Legal provides documented rationale for delay. This prevents both premature notification and missed deadlines.

Task 3 Security Governance Committee Ecosystem

3.1 Committee Structure / Interaction Diagram



Decision and Risk Information Flow:

1. Operational → Steering Committee: Working Groups and BU Security Champions escalate risks that exceed local authority or require cross-functional input.

2. Steering Committee → Executive Security Council: Risks requiring resource allocation, strategic trade-offs, or cross-functional deadlock resolution are escalated with documented assessment.

3. Executive Security Council → Board: Material risks, risk acceptance above CEO threshold, and strategic security decisions are escalated to the Board with full documentation.

4. Board → Executive → Steering → Working Groups: Risk appetite, strategy decisions, and policy approvals flow downward with clear implementation expectations.

3.2 Terms of Reference - Security Governance / Steering Committee

1. Purpose

The Security Governance / Steering Committee provides cross-functional governance for information security at TechGlobal. It reviews and decides on security policy, risk treatment, control effectiveness, and incident governance within the authority delegated by the Executive Security Council. It ensures that security decisions are business-aligned, legally compliant, financially sound, and operationally feasible.

2. Authority

The Committee has authority to:

- Approve security policies and standards within the approved strategy.
- Approve risk treatment plans for risks rated Medium or below.
- Escalate risks rated High or Critical to the Executive Security Council with recommendations.
- Commission Working Groups and define their terms of reference.
- Require business units to remediate control deficiencies within defined timeframes.
- Review and approve incident post-mortems and corrective actions.

3. Membership

- Chair: CISO
- Permanent Members: CRO delegate, Legal delegate, Finance delegate, HR delegate, IT Security lead
- Rotating Members: Business Unit representatives (each BU represented at least twice yearly)
- Working Group Leads: Incident Response, Cloud Security, Third-Party Risk (attend as required)
- Secretariat: GRC analyst (minutes, decision log, action tracking)

4. Frequency

- Monthly ordinary meetings (90 minutes)
- Extraordinary meetings within 48 hours for material incidents
- Annual strategy review session (half-day)

5. Quorum

Five members, including at least one of CISO, CRO delegate, or Legal delegate.

6. Decision-Making

- Decisions are made by consensus where possible.
- If consensus cannot be reached, the Chair (CISO) decides, with the decision documented and any dissent recorded.
- Decisions requiring resource allocation above the CISO's authority are escalated to the Executive Security Council.
- Decisions requiring risk acceptance above Medium are escalated with recommendation.

7. Reporting

- Minutes and decision log to Executive Security Council within 5 working days.
- Quarterly summary to Board Risk Committee via CISO.
- Annual report on governance effectiveness.

8. Review

Terms of Reference reviewed annually by the Executive Security Council.

3.3 Sample Committee Agenda (Monthly Ordinary Meeting)

TechGlobal Security Governance / Steering Committee

Date: 15 October 2026 | Time: 10:00–11:30 WAT | Location: Virtual + Lagos Office Boardroom

Time	Item	Lead	Paper
10:00	Welcome, apologies, quorum confirmation	CISO (Chair)	—
10:05	Review of previous minutes and action log	Secretariat	Paper 1
10:15	Incident review: September incidents and trends	SOC Lead	Paper 2
10:30	Risk register update: new and changed risks	CRO delegate	Paper 3
10:45	Policy review: Third-Party Security Policy (v2 draft)	Legal delegate	Paper 4
11:00	Working Group report: Cloud Security exposure findings	Cloud Security Lead	Paper 5
11:15	Business Unit feedback: local implementation challenges	BU Representative	Verbal
11:25	Any other business	Chair	—
11:30	Close and actions	Chair	—

Standing Items: Incident review, risk register update, action log review.

Rotating Items: Policy review, Working Group deep-dive, BU feedback, awareness metrics.

3.4 Sample Decision Log

Decision ID	Date	Decision	Rationale	Accountable	Status	Review Date
SGC-2026-042	15 Oct 2026	Approve Third-Party Security Policy v2 for implementation	Aligns with regulatory requirements; addresses third-party risk findings	CISO	Approved	Oct 2027
SGC-2026-043	15 Oct 2026	Escalate Cloud Exposure risk (3 incidents, avg $97K) to Executive Security Council	Exceeds Medium risk threshold; requires resource allocation for remediation	CISO	Escalated	Nov 2026

Decision ID	Date	Decision	Rationale	Accountable	Status	Review Date
SGC-2026-044	15 Oct 2026	Require all Business Units to complete security awareness training by 30 Nov 2026	Completion rate at 78%, below 95% target; Privacy exposure incidents increasing	HR	In Progress	Dec 2026

3.5 12-Month Governance Calendar

Month	Governance Activity	Forum	Milestone
Oct 2026	Q4 ordinary meeting; policy review	Steering Committee	Third-Party Policy approved
Nov 2026	Executive Security Council; awareness campaign launch	Executive Council	Awareness completion >90%
Dec 2026	Q4 Board reporting; annual risk appetite review	Board Risk Committee	Risk appetite reaffirmed
Jan 2027	Annual strategy review; governance effectiveness review	Executive Council + Board	Strategy 2027 approved
Feb 2027	Incident response tabletop exercise	IR Working Group	Lessons learned documented
Mar 2027	Q1 ordinary meeting; Cloud Security deep-dive	Steering Committee	Cloud remediation plan
Apr 2027	Executive Security Council; budget mid-year review	Executive Council	Budget variance <5%
May 2027	Third-Party Risk assessment cycle	TP Working Group	100% critical vendors assessed
Jun 2027	Q2 Board reporting; mid-year governance review	Board Risk Committee	Governance KPIs on target
Jul 2027	Annual policy review cycle begins	Steering Committee	Policy review schedule
Aug 2027	Business Unit governance participation review	Steering Committee	All BUs represented
Sep 2027	Annual governance report; 2028 planning	Board + Executive	2028 governance plan approved

Recurring Activities:

- Monthly: Steering Committee; Incident review; Risk register update
- Quarterly: Executive Security Council; Board Risk Committee reporting; Awareness metrics
- Annual: Strategy review; Risk appetite review; Governance effectiveness review; Policy review cycle

---

Task 4 RACI Accountability Matrix

4.1 TechGlobal RACI Matrix

Activity	Board	CEO	CISO	CRO/Risk	Legal	Finance	HR	IT	BU Leader
Cybersecurity strategy approval	A	R	R	C	C	C	I	I	I
Security policy approval	I	A	R	C	C	I	C	R	I
Enterprise cyber-risk assessment	I	C	R	A	C	C	I	C	C

Activity	Board	CEO	CISO	CRO/Risk	Legal	Finance	HR	IT	BU Leader
Risk acceptance (operational, below Board threshold)	I	A	R	R	C	C	I	I	C
Risk acceptance (enterprise, above Board threshold)	A	R	R	R	C	C	I	I	I
Security budget approval	A	R	R	C	I	R	I	C	I
Security architecture approval	I	C	A	C	I	I	I	R	I
Third-party security review	I	C	R	C	C	I	I	C	A
Access governance	I	I	A	C	I	I	I	R	C
Incident response governance	I	A	R	C	C	I	I	R	C
Material incident escalation	A	R	R	C	C	I	I	C	I
Regulatory notification decision	I	C	R	I	A	I	I	I	I
Security awareness programme	I	I	C	I	C	I	A	R	R
Vulnerability remediation oversight	I	I	A	C	I	I	I	R	C
Business continuity / recovery governance	I	A	R	C	C	C	C	R	R
Board cyber-risk reporting	A	C	R	C	I	I	I	I	I

R = Responsible, A = Accountable, C = Consulted, I = Informed. One Accountable per activity.

4.2 Problematic Assignments and Explanation

Problematic Assignment 1: Risk Acceptance (Operational) - CEO Accountable, CISO Responsible

Issue: The CEO is Accountable for operational risk acceptance, but the CISO is Responsible for providing the risk assessment. If the CISO's assessment is overruled by the CEO for business reasons, the CISO may feel accountability is compromised. Conversely, the CEO may accept risk without fully understanding the technical basis.

Mitigation: The CISO's risk assessment must be documented and attached to the risk acceptance record. The CEO's decision must reference the CISO assessment and document any deviation rationale. The CRO validates the risk rating. This ensures the CEO's acceptance is informed and auditable. If the CISO disagrees with the acceptance, the disagreement is documented and the CRO may escalate to the Board Risk Committee.

Problematic Assignment 2: Third-Party Security Review - BU Leader Accountable, CISO Responsible

Issue: Business Unit Leaders are Accountable for third-party security review, but they may lack the technical expertise to evaluate security posture. The CISO is Responsible for the assessment, but the BU Leader may be incentivised to approve vendors for business reasons despite security concerns.

Mitigation: The CISO provides the security assessment with a clear risk rating and recommendation. The BU Leader cannot approve a vendor rated High or Critical risk without CISO concurrence and, if necessary, CEO escalation. The CRO validates the risk rating. Legal reviews contractual protections. This balances business ownership with security oversight.

Problematic Assignment 3: Incident Response Governance -CEO Accountable, CISO Responsible

Issue: During an incident, the CEO is Accountable for governance, but the CISO is Responsible for command. If the CEO overrides the CISO's operational decisions (e.g., containment strategy, notification timing), response could be compromised. Conversely, if the CISO acts without CEO awareness on material issues, executive accountability is undermined.

Mitigation: The CISO has command authority during the response phase (containment, investigation, recovery). The CEO has governance authority over material decisions (notification, disclosure, resource allocation, ransom payment). The escalation workflow defines the handover points. The CISO briefs the CEO within 4 hours of a material incident; the CEO decides on external communications and regulatory notification (with Legal). This separation prevents both operational interference and accountability gaps.

4.3 One-Page Implementation Guide

RACI Matrix: Practical Use Guide

Before Starting a Security Project or Initiative

Before beginning any security project, initiative, or significant change, identify the relevant activity in the RACI matrix.

Confirm the following roles:

- **Accountable:** The single person who owns the decision, outcome, and consequences.
- **Responsible:** The individual or team that completes the work.
- **Consulted:** Individuals or teams whose input is required before the decision is made.
- **Informed:** Individuals or teams who must be notified after the decision has been made.

If the activity is not included in the RACI matrix, escalate the matter to the CISO or the Security Governance and Steering Committee before work begins. They must assign decision rights and accountability.

No security project or material security decision may proceed without one clearly named Accountable role.

During Approvals

When seeking approval for a security-related decision—such as a policy, security architecture change, risk acceptance, third-party exception, or budget request—consult the RACI matrix first to confirm the correct decision-maker.

- Obtain approval only from the role identified as **Accountable**.
- Do not treat approval from a **Consulted** or **Informed** party as authorization.
- If the Accountable person is unavailable, defer the decision or escalate it according to the approved escalation workflow.
- The Accountable person may delegate tasks and execution responsibilities, but not accountability for the final decision.
- The Accountable person must personally own the decision, rationale, and resulting consequences.
  Accountability may not be delegated; only responsibility for completing work may be delegated.

During Security Incidents

The RACI matrix distinguishes between **command authority** and **governance authority** during an incident.

Role	Authority during an incident
CISO	Has command authority for containment, investigation, recovery, and operational incident-response coordination.
CEO	Has governance authority for material business decisions, including external communications, resource allocation above approved limits, major operational trade-offs, and ransom-related decisions.
Legal / Compliance	Is accountable for regulatory-notification decisions, based on legal obligations and supported by the CISO's factual assessment of the incident.
Board / Board Risk Committee	Oversees material incident escalation and is accountable for final risk acceptance above the CEO's authority threshold.

Task 5: Escalation Workflow.

Do not delay urgent action while seeking consensus. The Accountable role makes the decision, and any dissenting views must be documented.

During Business-as-Usual Governance

Use the RACI matrix during Steering Committee meetings, project governance sessions, risk reviews, and policy discussions to establish decision rights before debate begins.

For each agenda item requiring a decision, the Chair should:

1. Identify the relevant RACI activity.

2. State the designated Accountable role.
3. Confirm that the Accountable role, or an authorized escalation path, is available.
4. Confirm which parties must be consulted before a decision is made.
5. Record the decision, rationale, owner, and any dissent in the decision log.

If the Accountable role is absent, defer the item or escalate it through the approved governance process.

- Consulted roles provide expertise and input before a decision.
- Consulted roles do not have veto power unless a policy, legal requirement, or decision framework explicitly grants it.
- Informed roles receive minutes, decision logs, reports, or notifications; they do not hold decision authority solely because they are informed.

Three Rules for Using This RACI

1. One Accountable Role per Activity

Each activity must have one clearly identified Accountable role. If the matrix does not identify a single accountable decision-maker, escalate the issue to the CISO for clarification.

A missing or unclear Accountable role is a governance gap and must be resolved before work proceeds.

2. Accountability Cannot Be Delegated

The Accountable person may delegate tasks, analysis, implementation, or administrative work to Responsible individuals or teams. However, the Accountable person remains responsible for the final decision and its consequences.

If you are Accountable, you must:

- Review the evidence and recommendations.
- Make or formally authorize the decision.
- Ensure the rationale is documented.
- Accept responsibility for the outcome.
- Escalate the decision if it exceeds your authority.

3. Consultation Does Not Require Consensus

Consulted roles provide relevant input, challenge assumptions, identify risks, and recommend alternatives. Their input must be considered, but consultation should not create unnecessary delay or prevent timely decision-making.

If a Consulted role disagrees with a decision:

- Record the dissent and supporting rationale.
- Allow the Accountable role to make the final decision.
- Escalate through the CRO, CISO, CEO, or Board Risk Committee where the matter exceeds the relevant risk threshold.
- Do not block implementation unless a legal, regulatory, policy, or explicitly defined governance requirement applies.

Common Mistakes to Avoid

Approaching the Wrong Person for Approval

Do not seek approval from the most senior available person if the RACI matrix assigns accountability to another role.

For example, if the CISO is Accountable for security architecture, the IT Director cannot approve an architectural deviation merely because they are responsible for technical implementation. The IT Director may propose alternatives, but the CISO must approve the security architecture decision or escalate it.

Confusing Responsible and Accountable Roles

Responsible means completing the work. Accountable means owning the decision and outcome.

For example, the Security Operations Center may be Responsible for detecting and investigating incidents, while the CISO is Accountable for incident-response governance. The SOC performs operational activities; the CISO owns the governance outcome.

Consulting Stakeholders Too Late

Consulted roles must be involved before the decision is made, not after implementation has begun.

For example, if Legal is Consulted on a third-party contract, Legal must review the agreement before it is signed. Late consultation can create rework, contractual exposure, regulatory noncompliance, and avoidable delays.

Informing Stakeholders Too Late

Informed roles should receive timely communication through the appropriate channel.

For material incidents, the Board should not learn about an issue through external media, a customer complaint, or a regulator. Internal notification must occur early enough to support oversight and preparedness.

Escalation Trigger

Escalate a RACI dispute when there is uncertainty about:

- Who is Accountable for an activity.
- Whether a Consulted party has a veto or advisory role.
- Whether an activity is missing from the RACI matrix.
- Whether a decision exceeds the Accountable role's delegated authority.
- Whether a dispute could delay material risk treatment, incident response, or regulatory action.

Escalate operational matters to the **CISO**. Escalate strategic, enterprise-risk, resource, or cross-functional disputes to the **CEO**. The Security Governance and Steering Committee is the formal forum for clarifying RACI assignments, and all approved changes must be documented in the decision log.

Document purpose: This guide should be distributed to managers, Steering Committee members, project leads, and incident-response personnel as a practical reference for using the RACI matrix consistently.